

# Security Policy

## Purpose

Room Clarity protects meeting transcript content, participant metadata, generated meeting artifacts, Zoom integration credentials, and service administration controls.

## Protected Data

Protected data includes:

- Meeting transcript text and cues.
- Participant names and meeting context.
- Generated decisions, risks, actions, and facilitation prompts.
- Zoom OAuth, webhook, and RTMS credentials.
- LLM provider API keys.
- Dashboard access tokens and admin tokens.

## Access Control

- Production secrets are stored outside source control.
- Meeting dashboard access uses scoped access tokens.
- Administrative inspection routes require `ROOM_CLARITY_ADMIN_TOKEN`.
- Zoom webhook traffic is verified with HMAC signatures and timestamp freshness checks.
- Access control improvements for external launch are tracked in `docs/security-launch-plan.md`.

## Application Security

- The service sends HSTS, Content Security Policy, `nosniff`, and referrer policy headers.
- Static files are served from the application directory with path normalization checks.
- Request bodies are size-limited.
- Selected public and inspection routes have rate limiting.
- Transcript text and model output are treated as untrusted input.

## Logging

Operational logs should avoid raw transcript content, OAuth tokens, webhook secrets, RTMS secrets, dashboard tokens, and model provider keys. Logs should prefer event type, counts, status, and non-sensitive identifiers.